Monthly Intelligence Dispatch

May 2019

The Group-IB Monthly Threat Intelligence Dispatch (Group-IB MTID) — is a monthly newsletter by Group-IB, an international company that specialises in preventing cyberattacks and developing information security products. The dispatch aims to provide information about the latest cyberthreats, criminal groups' attacks, leaks, and malware. The document contains news about arrests, legal action against hacking groups, short-term forecasts, and recommendations to help take timely measures to reduce security risks and ensure protection against cyberthreats. Group-IB MTID is intended for internal use only and its distribution is not permitted.

Key findings

- Group-IB reported about a discovered leak of email addresses of the Turkish corporation ASELSAN A.Ş. The pro-Iranian APT group **MuddyWater** is believed to be behind attacks on Turkish companies.
- The pro-government APT **Turla** uses PowerShell scripts and the **LightNeuron** backdoor in their attacks on EU diplomats.
- The Chinese group APT10 added two new malware loaders to its arsenal and is using them in attacks on private and government organisations in Southeast Asia.
- Despite the arrests of Fin7 leaders in August 2018, over **130** companies had been attacked by the hackers by the end of 2018.
- Group-IB observed new mass phishing emails that contained Troldesh (Shade) ransomware.
- An exploit of the CVE-2019-0708 vulnerability is on sale on an underground forum for $150,000. If threat actors use it, they could cause an epidemic similar to WannaCry and NotPetya.
- Europol shut down the world's leading cryptocurrency mixing service Bestmixer.io on suspicion of laundering $200 million.

MuddyWater

In May 2019, Group-IB reported about a discovered leak of email addresses of the Turkish corporation **ASELSAN A.Ş**, which manufactures tactical military radio stations and electronic defence systems for the Turkish Armed Forces. These data were used by MuddyWater, an APT group linked to the Iranian government, to attack the company. **MuddyWater** has been active since 2017 in the Middle East targeting educational, financial, government, telecommunications and defence organisations in Turkey, Iran, Afghanistan, Iraq, and Azerbaijan.

Group-IB's analysis of one of the new malware samples revealed that as a decoy document the hackers used the license agreement between **Koç Savunma**, a manufacturing company, and **Tubitak Bilgem**, a research centre. Once a user activates the malicious macros in the file, the PowerShell-based **POWERSTATS** developed by **MuddyWater** is loaded onto the victim's computer.

One of the detected documents contains a list of 34 email addresses belonging to the **@aselsan.com.tr** domain. Group-IB specialists checked email addresses in publicly accessible leaks and discovered that 28 of them had been compromised in previously detected leaks. The analysis of available leaks revealed about 400 unique logins and passwords associated with this domain. The attackers may have used these publicly available data to attack ASELSAN A.Ş.

One of the discovered samples was a document called **F35-Specifications.doc**, which referred to the F-35 fighter aircraft. The bait document lists specifications of the multifunctional F-35 fighter-bombers and mentions the aircraft's characteristics and price. All of the findings suggested that Turkey-based organisations were the main target of MuddyWater's cyber attacks.

Major events: espionage, sabotage, leaks

APT Turla

The pro-government **APT Turla** (also known as Snake, Uroburos, and Waterbug) has been using **PowerShell** scripts to attack EU diplomats and a complex backdoor called **LightNeuron** to hijack Microsoft Exchange mail servers, ESET reports. The experts have identified three different organisations that were infected with the malware, including the Ministry of Foreign Affairs of an Eastern European country, a regional diplomatic organisation in the Middle East, and an entity in Brazil. Turla has targeted government organisations and private businesses since 2007. The list of their victims includes the Swiss defence firm RUAG, the US Department of State, and the US Central Command.

ScarCruft

The North Korea-linked APT group **ScarCruft** (also known as APT37, Reaper, and Group123) has added **Bluetooth Harvester** to their arsenal. The ScarCruft hackers have been active since 2012. Cyber attacks conducted by the APT37 group mainly target government, defence, military, and media organisations in South Korea. Researchers from FireEye revealed that ScarCruft hackers targeted entities in Japan, Vietnam, and the Middle East in 2017.

Winnti

Security experts from Chronicle discovered a Linux variant of the backdoor used by hackers from the China-linked Winnti group. The Linux variant was spotted on VirusTotal. The malware was used to hack a Vietnamese gaming company circa 2015. The experts believe that there are several APT groups under the Winnti umbrella, including Winnti, Gref, PlayfullDragon, APT17, DeputyDog, Axiom, BARIUM, LEAD, PassCV, Wicked Panda, and ShadowPad. The groups show similar tactics, techniques, and procedures (TTPs) and in some cases share portions of the same hacking infrastructure.

Emissary Panda

Another Chinese APT group called Emissary Panda (also known as APT27, TG-3390, Bronze Union, and Lucky Mouse) targets government organisations in two Middle Eastern countries, according to experts from Palo Alto Networks. The hackers exploited the CVE-2019-0604 vulnerability to breach SharePoint servers. Once the attackers hack into a network, they can load additional malware. The experts note that the threat actors used tools to identify systems vulnerable to CVE-2017-0144, the infamous vulnerability related to NSA's EternalBlue exploit. The Emissary Panda APT group has been active since 2010 and has targeted US defence companies, financial firms, and a national data centre in Central Asia.

APT10

Another Chinese group called APT10 has added two new malware loaders to its arsenal and is using them in attacks on private and government organisations in Southeast Asia. APT10 has been active since 2009. In April 2017, experts from PwC UK and BAE Systems observed a campaign called **Operation Cloud Hopper**, which targeted managed service providers (MSPs) in many countries. In July 2018, FireEye observed a series of new campaigns conducted by the group, in which the hackers used phishing emails in an attempt to deliver the UPPERCUT (ANEL) backdoor. Later, in September 2018, FireEye researches detected another cyber espionage campaign by APT10 that targeted the Japanese media sector.

Major events: attacks on banks and their customers

MoneyTaker

In April 2019, specialists from Group-IB's Digital Forensics Lab detected activity of the MoneyTaker group and a previously unknown Visual Basic-based backdoor. The new malware was named MTHole.VBE. The backdoor's main task is to execute commands from the C2 server. The experts did not find any mentions of this tool on the Internet, on VirusTotal, similar services, or in sandboxes. They received three VBScript Encoded Script format files for analysis and based on a previous examination of the infrastructure concluded that the files were related to three attacks in 2016, 2018, and 2019.

Silence

Group-IB detects new activity of the **Silence** group, which has sent out new mass emails to the Netherlands and Belgium since 25 May 2019. The specialists have detected a domain registered by Silence. To carry out their campaigns, the attackers compiled two lists of recipients. One for recipients based in Belgium (sender: Beobank), the other for those in the Netherlands (the emails were disguised as coming from Spotify).

Lazarus

Group-IB specialists discovered and analysed a new backdoor by Lazarus. The malware can be classified as the PowerTask backdoor and is used by Lazarus to attack banks. The file stage.ps1 was uploaded to VirusTotal on 29 March 2019 from Nigeria, which means that there may have been attacks on banks in that country.

Troldesh	Group-IB experts observed new phishing campaigns with more than a thousands emails (about 1,200) that contained Troldesh (Shade) ransomware. In the emails, the attackers claim they are managers of major Russian banks or airlines and ask the recipients to open the email attachment for more details about their order, with the password for the archive provided. Troldesh has been the most popular ransomware lately. In 2018, Group-IB's Incident Response team found its traces in at least seven incidents. In addition to encrypting cryptocurrencies, Troldesh has recently started mining them. Group-IB first detected Troldesh in 2015. PaloAlto Network experts believe that Russia is not the only country Troldesh is active in. Among its victims are targets in the US, Japan, India, Thailand, and Canada. The number of Troldesh infections increased in October 2018 and doubled in early 2019.
Fin7	Despite the arrests of Fin7 leaders in August 2018, the hackers attacked over **130** companies, with their cyberattack methods becoming increasingly complex, **Kaspersky Lab** reported. The hackers sent out malware via phishing emails throughout 2018. In some cases, the operators exchanged messages with their intended victims for weeks before finally sending the malicious documents as attachments. Kaspersky Lab believes Fin7 might have extended the number of groups operating under its umbrella and recruited professional employees. Fin7 has been active since mid-2015, primarily attacking US retail and hospitality businesses.

Major events: malware

UDJAT	A post on an underground forum advertised a new Hidden VNC type malware called UDJAT. The remote access Trojan can run on Windows versions ranging from XP to 10 (x32/x64) and Windows Server 20XX. Renting UDJAT for one month costs $1,500 and $3,800 for three months. Earlier this month, the seller nicknamed h21 made a post about the same Trojan only with additional features (surveillance of the victim's screen) on another forum, nulled.to.
Silence	Group-IB specialists established that the programs FlawedAmmyy.Loader and Silence.Downloader had been created by the same person. In late 2018, Silence sent malware signed with the same certificate as FlawedAmmyy (CP-1645-13) twice. There are suggestions that the author is a Russian speaker who develops software for hackers. FlawedAmmyy Loader was first detected in the early summer of 2018 and has since been used in attacks in different regions worldwide.
CVE-2019-0708	Group-IB specialists have discovered an underground forum user nicknamed 500mhz, who claims they possess a working exploit of the CVE-2019-0708 vulnerability and sells it for USD 150,000. Microsoft released a patch for this vulnerability as early as 14 May 2019. However, if attackers obtain the exploit, they could start an epidemic similar to that of **WannaCry** and **NotPetya** ransomware, which infected hundreds of thousands of computers worldwide. On 15 May 2019, some GitHub users started creating repositories with fake versions of the PoC exploit for CVE-2019-0708.

Arrests and sentences

Bestmixer.io

Europol and the Dutch Fiscal Information and Investigation Service (FIOD) shut down the world's leading cryptocurrency mixing service Bestmixer.io on suspicion of laundering $200 million. Bestmixer.io was launched in May 2018 and offered services for mixing cryptocurrencies, Bitcoin, Bitcoin Cash and Litecoin. The service achieved a turnover of at least $200 million (approximately 27,000 bitcoins) in a year's time and guaranteed that the customers would remain anonymous. The investigation revealed that many of the cryptocurrencies mixed on Bestmixer.io had a criminal origin or destination. Initiated back in June 2018 by the FIOD with the support of McAfee, the investigation resulted in the seizure of six servers in the Netherlands and Luxembourg. The investigators obtained IP-addresses, transaction details, bitcoin addresses and chat messages. This information will now be analysed by the FIOD in cooperation with Europol.

Forecasts and warnings

- Despite numerous “secret leaks” of information about Iran-linked APT groups this spring, their attacks continue. Turkish companies are at risk of being targeted by the **MuddyWater** APT.
- Southeast Asia remains a source of tension due to cyber espionage by Chinese APT groups. We estimate that their activity will only increase.
- Group-IB experts’ forecast about new activity of the Silence group outside Russia has proven true. We forecast new Silence attacks not only in Southeast Asia, but also in Europe.
- The number of mass emails containing Troldesh (Shade) ransomware will increase.
- If attackers obtain the exploit for the CVE-2019-0708 vulnerability, they could start what will be similar in scale to the WannaCry and NotPetya ransomware infections of hundreds of thousands of computers worldwide.

If you wish to receive more detailed information about a specific incident, threat or criminal group:

Please contact us.

We can conduct investigations to give you the maximum intelligence on the threats targeting your organisation.

+1 917 809 47 41
+7 495 984 33 64
intelligence@group-ib.com